YUKTHI 2026

TEAM: BRUTE FORCE

SupplyGraph

BLOCKCHAIN & CYBERSECURITY TRACK

Zero-Trust Software Supply-Chain Attack Graph | AI Code Reviewer | Universal Sandbox Platform

WORKING PROTOTYPE — EVIDENCE-LINKED

Frontend: https://supplygraph-five.vercel.app | GitHub: hemanthreddydaram-007/supplygraph (3380e39)

Automated Tests: 130/130 Passed | Coverage: 74% Full-Suite Line Coverage (Core Engines: 87%-100%)

Evidence Dossier: docs/EVIDENCE.md | Target: Polygon Amoy Testnet (Deployment Pending)

Test coverage and passing tests do not constitute an independent security audit.

2 Problem Statement

The AI Code Crisis & Software Supply-Chain Vulnerability Epidemic

VERACODE 2025: 45% AI CODE FLAW RATE

AI-Generated Code Security

01

Veracode 2025 GenAI Code Security Report evaluated 100+ LLMs across 80 coding tasks: 45% of generated code samples failed security tests and introduced OWASP Top-10 flaws (SQLi, XSS, hardcoded credentials, broken access control). This is a controlled-test result, not an estimate across all production code.

Source: Veracode GenAI Code Security Report 2025

Open-Source Dependency Complexity

02

Synopsys OSSRA 2024 reported 96% of assessed codebases contained open source and 77% of scanned code originated from open source. Vulnerable transitive packages increase downstream risk when affected components are present and relevant exploit conditions are met across npm, PyPI, Go, and Cargo.

Source: Synopsys OSSRA 2024 & Sonatype State of Supply Chain

Fragmented Risk Context

03

Existing tools identify dependency vulnerabilities, transitive trees, and source flaws in isolation. SupplyGraph combines a custom multi-ecosystem dependency graph, downstream-impact scoring, source findings, and CI workflow findings in one unified investigation workflow.

Source: Ponemon Institute Vulnerability Management Benchmark

Install-Time Threats

04

Static analysis can identify suspicious patterns in lifecycle scripts and binaries, but cannot establish runtime behavior. Isolated dynamic analysis reveals execution telemetry when untrusted scripts run under enforced resource and isolation controls (npm postinstall, setup.py, PE/ELF/WASM).

Source: OpenSSF & Socket Malicious Package Research 2024

Tamper-Evident SBOM Records

05

SupplyGraph records a cryptographic SBOM digest on Polygon Amoy so a verifier can detect post-build tampering against the recorded digest. This supports integrity auditing without claiming automatic completeness, build provenance, or full compliance with NIST SSDF, EO 14028, or SLSA.

Source: NIST SP 800-218 (SSDF) & Executive Order 14028 Section 4

3 Proposed Solution

SupplyGraph v3.5: Autonomous ASPM & Universal Sandbox Platform

DEPENDENCY ATTACK GRAPH ENGINE

01

Collapses circular dependencies via Tarjan SCC condensation into a NetworkX Reverse DAG (up to 10 hops) across npm, PyPI, Go, and Cargo. Computes Blast Radius B = min(100, 2P+15S+25A+50D) (P: Packages, S: Services, A: Admin Context, D: Direct Exploit) and Confidence C = 1-Prod(1-wi*ri). Virtualized @xyflow/react canvas targets 60 FPS across 633 nodes (wasmtime worked example: P=16, S=1 -> B=47/100, C=0.88).

TWO-TIER AI CODE REVIEW ENGINE (<50ms Deterministic Scan)

02

Two-tier engine: (1) Deterministic Python AST + Token-Sanitized Pattern Engine scans Python, JS/TS, Go, and Rust in <50ms/file (p95: 38ms) with zero LLM latency; (2) Google Gemini 2.5 Flash synthesizes context-aware unified-diff remediation PRs (~1.2s/finding) for SQLi, XSS, SSRF, and secrets.

INSTALL-HOOK SANDBOX & STATIC BINARY INSPECTOR

03

Runs supported npm lifecycle hooks and setup.py scripts in a resource-limited Docker environment (--network none, 512MB RAM, 10s watchdog, default seccomp) with subprocess fallback. Static PE/ELF/WASM indicator extraction without executing host binaries (reduces exposure; does not guarantee zero host risk).

CI/CD PIPELINE SECURITY AUDITOR (SLSA + MITRE)

04

Parses GitHub Actions and GitLab CI YAML workflows to flag unpinned action SHAs, unpinned container images, curl|bash execution, write-all permissions, and OIDC token misuse. Maps findings to SLSA provenance gaps and MITRE ATT&CK CI/CD TTPs with least-privilege YAML fixes.

POLYGON AMOY SBOM INTEGRITY ATTESTATION (CycloneDX SHA-256)

05

Generates CycloneDX SBOMs and calculates deterministic SHA-256 digests. Anchoring target: Polygon Amoy Testnet (Chain ID: 80002; scripts/deploy_amoy.py) to provide a tamper-evident audit reference supporting post-build integrity verification.

4 Key Features

CORE CAPABILITIES — 5 Integrated Security Modules

F1 — Attack Graph Visualization (60 FPS / 633 Nodes)

Tarjan SCC + NetworkX Reverse DAG renders 633 nodes & 891 edges (vercel/next.js benchmark) at 60 FPS via @xyflow/react virtualization. Computes Blast Radius B (0-100) and Confidence C (0-1).

F2 — Two-Tier Code Reviewer (<50ms AST + Gemini 2.5 Flash)

Tier-1 Python AST + Token-Sanitized Pattern Engine scans code in <50ms/file (p95: 38ms); Tier-2 Gemini 2.5 Flash generates unified-diff remediation patches for SQLi, XSS, SSRF, and secrets.

F3 — Behavioral Sandbox & Binary Inspector (--network none)

Isolated Docker runner with subprocess watchdog fallback (--network none, 512MB RAM, 10s cap, default seccomp) executes install hooks, plus static indicator extraction for PE/ELF/WASM binaries.

F4 — Blockchain SBOM Attestation (Polygon Amoy Testnet)

CycloneDX SBOM SHA-256 digest with automated verification (Target: Polygon Amoy Testnet, Deployment Pending). Provides tamper-evident audit reference for post-build integrity verification.

F5 — CI/CD Pipeline Auditor (GitHub Actions & GitLab CI)

Audits GitHub Actions & GitLab CI YAML for curl|bash, write-all tokens, unpinned SHAs/images, and OIDC risks. Maps findings to MITRE ATT&CK CI/CD TTPs and outputs pinned SHA patches.

SUPPLYGRAPH vs EXISTING TOOLS — Checked Oct 2026

Feature (F1–F5)	SupplyGraph	Snyk	Dependabot	SonarQube	Socket
F1: Interactive Multi-Hop DAG Canvas	✅ Yes	⚠ Partial	❌ No	❌ No	❌ No
F1: Blast Radius Score Formula	✅ Yes	⚠ Partial	❌ No	❌ No	❌ No
F1: Cross-Ecosystem Path Reachability	✅ Yes	✅ Yes*	❌ No	⚠ Partial	❌ No
F1: 4-Ecosystem Manifest & Lockfile Graph	✅ Yes	✅ Yes	✅ Yes	⚠ Partial	⚠ Partial
F2: LLM Diff Patching	✅ Yes	✅ Yes*	❌ No	✅ Yes*	❌ No
F2: Unified SAST + SCA + Sandbox Triage	✅ Yes	⚠ Partial	❌ No	❌ No	❌ No
F3: Isolated Install-Hook Execution	✅ Yes	❌ No	❌ No	❌ No	⚠ Partial*
F3: Static PE/ELF/WASM String Audit	✅ Yes	❌ No	❌ No	❌ No	⚠ Partial
F4: On-Chain SBOM Attestation	✅ Yes	❌ No	❌ No	❌ No	❌ No*
F5: CI/CD Workflow Permission & SHA Audit	✅ Yes	⚠ Partial	❌ No	⚠ Partial	⚠ Partial

**Snyk: call-graph reachability (Java/JS) & DeepCode AI Fix; SonarQube: AI CodeFix; Socket: static install-script checks (isolated hook execution marked Partial* per public docs). Sigstore: complementary signing and Rekor transparency logging. Verified against official vendor docs, Oct 2026.*

5 Implementation Approach

4-Stage Security Pipeline — End-to-End Autonomous Supply-Chain Analysis

STAGE 1 REPOSITORY GRAPH BENCHMARK

✓ vercel/next.js: 500 Components -> 633 Nodes, 891 Edges (Built in 1.8s, Peak 142MB RAM)

>> Manifest & Lockfile Ingestion: Parses package-lock.json, package.json, requirements.txt, pyproject.toml, go.mod, and Cargo.lock across 4 ecosystems + CycloneDX SBOM export.

>> SCC Condensation & PURL Resolution: Normalizes canonical PURLs via asyncio/HTTPX and collapses cyclic dependencies via Tarjan SCC into a 10-hop Reverse DAG.

STAGE 2 LABELED FINDING BENCHMARK

✓ axios/axios: 60 Findings (56 True Positives — 93.3% Precision, p95: 38ms/file)

>> Parallel 5-Layer Threat Engine: Batch OSV.dev CVE queries + Levenshtein typosquatting (0.85 threshold tuned on popular whitelist) + private-scope dependency confusion + CI/CD YAML audit.

>> Two-Tier Code Reviewer: Tier-1 deterministic Python AST (for .py) + Token-Sanitized Pattern Engine (strips comments/strings for JS/TS, Go, Rust) in <50ms/file; Tier-2 Gemini 2.5 Flash remediation PR synthesis.

STAGE 3 GRAPH AND RISK SCORING

✓ bytecodealliance/wasmtime: 94 Components, 16 Findings, Blast Radius 47/100, C=0.88

>> NetworkX Reverse-DAG Reachability: Traces multi-hop exploit paths from nested CVEs back to root production entrypoints; rendered at 60 FPS via @xyflow/react virtualization.

>> Closed-Form Risk Scoring: Computes Blast Radius B = min(100, 2P+15S+25A+50D) (P: Packages, S: Services, A: Admin Context, D: Direct Exploit) and Confidence C = 1-Prod(1-wi*ri).

STAGE 4 TESTS AND ATTESTATION

✓ 130/130 Pytest Suite Passing (74% Full-Suite Line Coverage) | Target: Polygon Amoy

>> Behavioral Sandbox & Binary Audit: Executes postinstall/setup.py hooks in an isolated Docker container with subprocess fallback (--network none, 512MB RAM, 10s cap, default seccomp) + static PE/ELF/WASM C2 string extraction.

>> LLM Patching & Polygon Anchor: Gemini 2.5 Flash generates unified-diff remediation PRs (~1.2s/finding); Web3.py anchors CycloneDX SHA-256 digest on Polygon Amoy (Chain ID: 80002).

6 Technology Stack

Full-Stack Engineering Blueprint — Unified, Deployed Cyber Security Pipeline

UI LAYER	Next.js App Router TypeScript UI	@xyflow/react 60-FPS DAG Canvas	Tailwind CSS shadcn/ui	Recharts Security Telemetry
API LAYER	FastAPI Python 3.11-3.12	Pydantic v2 Schema Validation	SQLAlchemy 2 Async ORM	Uvicorn ASGI HTTPX Asyncio
ANALYSIS ENGINE	NetworkX 3.x Tarjan SCC + DAG	Python AST + Token-Sanitized	CycloneDX Custom SBOM Gen	OSV.dev Batch API CVE Intelligence
AI / SANDBOX	Gemini 2.5 Flash AI Triage & Review	AWS Bedrock Claude 3.5 Fallback	Isolated Sandbox --network none	5-Layer Threat Detection Engine
STORAGE / CHAIN	Supabase PostgreSQL 15	Web3.py Polygon Amoy PoS	Alembic DB Migrations	GitHub Actions 130/130 Pytest CI

DEPLOYMENT & VERIFICATION (https://supplygraph-five.vercel.app): Vercel (Next.js UI) >> Render Docker Runtime (FastAPI + Isolated Subprocess Sandbox Worker: --network none, 512MB RAM, 10s Cap) >> Supabase PG 15 >> Target: Polygon Amoy Testnet (Deployment Pending) >> GitHub Actions (130/130 Pytest, 74% Coverage)